

Plan Integral de Ciberseguridad — Instituto Tecnológico CREATIC

Documento Técnico Principal · Maestría en Ciencias Computacionales (UTP) · Tópicos Especiales

Estructura del PDF final (20–30 páginas). Este documento es la **plantilla de ensamblaje**: el contenido detallado vive en los archivos `docs/M1..M7`. Para producir el PDF, se exportan las secciones en este orden (con los diagramas Mermaid renderizados como imágenes). Comando sugerido de exportación al final del documento.

Portada

- **Título:** Diseño e Implementación de un Plan Integral de Ciberseguridad para CREATIC
- **Asignatura:** Tópicos Especiales · **Profesor:** Xavier Trujillo · **Grupo:** 1M3213
- **Enfoque:** Zero Trust + Defensa en Profundidad · **Presupuesto de licencias:** \$0 (Open Source)

Resumen ejecutivo (1 página)

El Instituto CREATIC migró a un modelo digital híbrido sin una estrategia de seguridad, lo que derivó en spear-phishing exitoso, credenciales comprometidas, ransomware y una red plana sin control perimetral moderno. Este proyecto rediseña su seguridad bajo **Zero Trust** (verificar continuamente, mínimo privilegio, asumir la brecha) y **Defensa en Profundidad**, usando **exclusivamente herramientas Open Source de nivel empresarial** (costo de licencias = \$0).

Las palancas principales: **microsegmentación por VLANs** y **NGFW con IPS/IDS** (OPNsense + Suricata); **ZTNA con MFA y postura de dispositivo** (Headscale + Keycloak) en reemplazo de la VPN PPTP/L2TP; **SOC/SIEM** con Wazuh; **pipeline SecDevOps** con SAST/DAST/SCA; **automatización de hardening** (Ansible + PowerShell); y un marco de **cumplimiento (Ley 81)** y **gestión de riesgos + respuesta a incidentes** (NIST 800-30/61). El resultado reduce todos los riesgos críticos a niveles medios/bajos y deja a la institución en condición de defender su diligencia ante la ANTAI.

Índice y orden de ensamblaje del PDF

Sección	Contenido	Fuente
1	Resumen ejecutivo	(arriba)
2	Contexto organizacional e inventario	CONTEXTO_PROYECTO.md
3	M1 Panorama de amenazas (Mandiant/MITRE/CISA) + triada CIA	docs/M1-amenazas.md
4	M2 Arquitectura Zero Trust + diagramas Antes/Después	docs/M2-arquitectura.md + diagramas/

5	M5 Automatización de hardening (código)	ansible/ , powershell/ + docs embebidos
6	M3 SOC/SIEM (Wazuh)	docs/M3-soc-siem.md + siem/
7	M4 Ciclo de desarrollo seguro (SecDevOps)	docs/M4-secdevops.md + cicd/
8	M6 Cumplimiento Ley 81 (anexo normativo)	docs/M6-cumplimiento-ley81.md
9	M7 Gestión de riesgos + IRP	docs/M7-riesgos-irp.md
10	Matriz de trazabilidad marco → control → entregable	plan/matriz-trazabilidad.md
11	Conclusiones y hoja de ruta de implementación	(abajo)

Contraste Antes / Después (resumen visual para el PDF)

Dimensión	Estado Actual (Antes)	Estado Propuesto (Después)
Topología	Red plana única	6 VLANs microsegmentadas + NGFW inter-VLAN
Perímetro	Firewall stateful, sin IPS	OPNsense + Suricata (IPS/IDS, L7)
Acceso remoto	VPN PPTP/L2TP, usuario+clave	ZTNA Headscale + MFA + postura
Identidad	Sin MFA	Keycloak (TOTP/WebAuthn)
Endpoints	AV por firmas; BYOD ciego	EDR Wazuh; BYOD en cuarentena/postura
Monitoreo	Inexistente	SOC con Wazuh (SIEM) + reglas ATT&CK
Desarrollo	FTP/SCP manual	CI/CD con SAST/DAST/SCA
Datos (BD)	Sin cifrado, segmento compartido	Cifrado at-rest + aislamiento 3306
Cumplimiento	Sin marco	Ley 81 mapeada (MFA, cifrado, retención)

Diagramas: `diagramas/topologia-antes.mmd` , `diagramas/topologia-despues.mmd` , `diagramas/flujo-auth-mfa.mmd` .

Conclusiones y hoja de ruta

- Quick wins (semana 1–2):** hardening automatizado (M5), deshabilitar SMBv1, MFA en accesos críticos. Bajo costo, alto impacto.
- Columna vertebral (semana 3–6):** microsegmentación VLAN + NGFW + ZTNA (M2).
- Visibilidad (semana 5–8):** desplegar Wazuh y las reglas de correlación (M3).
- Desarrollo seguro (semana 6–9):** migrar a CI/CD con compuertas (M4).
- Gobierno continuo:** operar el SOC, revisar la matriz de riesgos y ensayar el IRP.

Viabilidad económica: costo de licencias **\$0**; la inversión es en horas de ingeniería y hardware/VMs existentes — sostenible para una institución educativa.

Módulo 1 — Panorama de Amenazas y relación con el caso CREATIC

Peso en la rúbrica: 15% (junto con M6). Fuentes: **Mandiant M-Trends 2026** (Edición Ejecutiva, Mandiant/Google Cloud) + fuente secundaria **CISA**. Marco de mapeo de adversarios: **MITRE ATT&CK**.

Sobre las citas de Mandiant. Las cifras citadas provienen de la **Edición Ejecutiva** del informe M-Trends 2026 (12 páginas, descarga gratuita de Google Cloud). Los números de página corresponden a esa edición. Si tu profesor exige el **informe completo** (~150 págs), descárgalo también desde el mismo portal y ajusta los números de página; las cifras son las mismas. **Descarga gratuita:**
<https://cloud.google.com/security/resources/m-trends> (edición ejecutiva directa:
<https://services.google.com/fh/files/misc/m-trends-2026-executive-edition-en.pdf>).

1. Panorama de amenazas actual (datos M-Trends 2026)

El informe **M-Trends 2026** de Mandiant (basado en **450,000 horas** de respuesta a incidentes durante 2025) describe un ecosistema de amenazas que coincide punto por punto con lo que sufrió CREATIC:

Hallazgo M-Trends 2026	Cifra	Cita	Relevancia para CREATIC
Vector de acceso inicial #1: explotación de vulnerabilidades	32% , 6.º año consecutivo	<i>M-Trends 2026 Ed. Ejecutiva, p. 3</i>	CREATIC tiene servidores sin parches (CR-DC-01, 6 meses) y SMBv1 activo → blanco directo
2.º vector: vishing (phishing de voz)	11% (subió)	<i>Ed. Ejecutiva, p. 3</i>	Ingeniería social a docentes; el spear-phishing fue el vector real de CREATIC
Email phishing en descenso pero vigente	14% (2024) → 6% (2025)	<i>Ed. Ejecutiva, p. 3</i>	Justifica MFA resistente a phishing (M2)
Dwell time global (permanencia del atacante)	14 días (subió desde 11)	<i>Ed. Ejecutiva, p. 2–3</i>	Sin SOC, CREATIC no detectaría la intrusión durante ~2 semanas → urgencia de Wazuh (M3)
Detección: interna vs. notificación externa	52% interna / 34% externa / 14% por el adversario	<i>Ed. Ejecutiva, p. 3</i>	Un SOC propio (Wazuh) sube la detección interna y reduce el MTTD
"Time to Hand-Off" colapsó	de >8 h (2022) a 22 segundos (2025)	<i>Ed. Ejecutiva, p. 5</i>	Los <i>initial access brokers</i> venden el acceso en segundos → hay que contener y detectar rápido (Zero Trust + SIEM)
Motivación: financiera vs. espionaje	41% financiera / 16% espionaje	<i>Ed. Ejecutiva, p. 3</i>	Las finanzas y calificaciones de CR-DB-01 son blanco económico atractivo

Fuente secundaria (CISA): los avisos de CISA para el sector educativo (K-12 / Higher Ed) coinciden en priorizar **MFA, segmentación de red y monitoreo de logs** como controles de mayor impacto-costo

— exactamente los ejes de este proyecto. (Completar con el aviso/URL específico de CISA que cites; p. ej. la guía "Online Safety / K-12 Cybersecurity" de CISA.)

2. Lectura del caso CREATIC a la luz de M-Trends 2026

Los incidentes que ya sufrió CREATIC son una instancia local de las tendencias globales:

- **Spear-phishing exitoso a docentes** → coincide con el peso del phishing/vishing como vector inicial (p. 3). El factor humano es la puerta de entrada.
- **Credenciales administrativas en la Dark Web** → alimenta el *credential stuffing* y el uso de *cuentas válidas*; combinado con el mercado de *initial access brokers* (hand-off de 22 s, p. 5), una credencial filtrada se convierte en intrusión casi instantánea.
- **Ransomware en equipos remotos** → habilitado por SMBv1 y la falta de EDR; el dwell time de 14 días (p. 2–3) explica por qué el daño escala antes de ser detectado.
- **Red plana sin control** → facilita el movimiento lateral que sigue a la explotación inicial.

3. Mapeo de los 3 vectores del caso a MITRE ATT&CK

El enunciado exige mapear **phishing avanzado**, **credential stuffing** y **movimiento lateral**. Se traducen a técnicas concretas de MITRE ATT&CK, cada una con su control en el proyecto:

3.1 Phishing avanzado (Acceso Inicial)

Táctica / Técnica ATT&CK	Cómo aplica a CREATIC	Control que lo mitiga
TA0001 Initial Access → T1566 Phishing (.001 adjunto / .002 enlace)	Spear-phishing y vishing a docentes	MFA resistente a phishing (M2), filtrado de correo, concienciación
T1204 User Execution	El docente abre el adjunto/enlace malicioso	EDR Wazuh en endpoint (M3), control de postura (M2)

3.2 Credential stuffing / cuentas válidas

Táctica / Técnica ATT&CK	Cómo aplica a CREATIC	Control que lo mitiga
T1110.004 Credential Stuffing	Reúso de credenciales filtradas en la Dark Web	MFA (M2) + regla Wazuh 100010 (M3)
T1078 Valid Accounts	Credenciales admin comprometidas usadas como acceso legítimo	Mínimo privilegio + MFA (M2), alertas de uso anómalo (M3)
T1133 External Remote Services	Acceso por la VPN PPTP/L2TP insegura	Reemplazo por ZTNA + postura (M2)

3.3 Movimiento lateral (Post-explotación)

Táctica / Técnica ATT&CK	Cómo aplica a CREATIC	Control que lo mitiga
TA0008 Lateral Movement → T1021 Remote Services	Pivote del web server a la BD en la red plana	Microsegmentación VLAN (M2) + ufw (M5)

T1210 Exploitation of Remote Services	Explotar SMBv1 / servicios expuestos	SMBv1 deshabilitado (M5) + regla Wazuh 100030 (M3)
T1570 Lateral Tool Transfer	Mover herramientas entre hosts	NGFW egress + segmentación (M2)

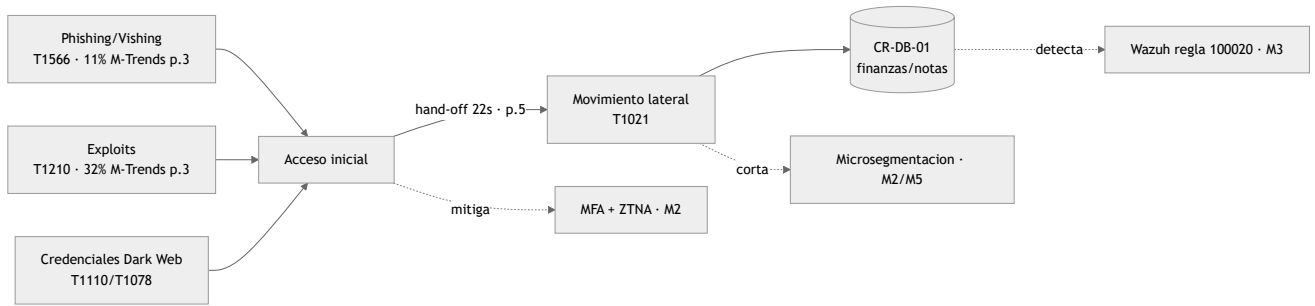
Esta tabla es el **punto amenaza→arquitectura**: cada técnica del adversario tiene un control nombrado y un archivo del repo que lo implementa (ver `plan/matriz-trazabilidad.md`).

4. Evaluación de la triada CIA de los activos críticos

Impacto potencial sobre **Confidencialidad (C)**, **Integridad (I)** y **Disponibilidad (D)** de cada activo (escala Bajo/Medio/Alto/Crítico):

Activo	Datos / función	C	I	D	Justificación del impacto
CR-DB-01 (MySQL finanzas/notas)	Calificaciones y finanzas	Crítico	Crítico	Alto	Una fuga viola privacidad (Ley 81); alterar notas/finanzas es fraude
CR-DC-01 (DC/DNS/DHCP)	Identidad del dominio	Alto	Crítico	Crítico	Comprometer el DC = control total; su caída paraliza todos los servicios
CR-APPSRV-02 (Portal web)	Servicio académico expuesto	Medio	Alto	Alto	Cara expuesta a Internet; su compromiso es el trampolín al resto
CR-FILE-03 (archivos admin)	Documentos administrativos/RR.HH.	Alto	Alto	Medio	Permisos "Everyone" exponen la confidencialidad de datos sensibles

Lectura Zero Trust: los activos con C/I **crítico** (CR-DB-01, CR-DC-01) son los que más se benefician de microsegmentación, cifrado y MFA. La triada CIA justifica priorizarlos y alimenta directamente la **matriz de riesgos del Módulo 7**.



5. Resumen de controles del Módulo 1 (para la matriz de trazabilidad)

- Inteligencia de amenazas → M-Trends 2026 (p. 2–5) + CISA → este documento
- Mapeo de TTPs → MITRE ATT&CK → tablas §3 + reglas Wazuh (M3)
- Evaluación CIA → base de priorización → alimenta M7 (matriz de riesgos)

Sources / referencias web consultadas:

- [M-Trends 2026 — Google Cloud Blog](#)
- [M-Trends 2026 Executive Edition \(PDF\)](#)

Módulo 2 — Arquitectura de Red Moderna (Zero Trust & SASE)

Peso en la rúbrica: 25% (Diseño de Arquitectura Zero Trust y Viabilidad Económica). Marcos de referencia: **NIST SP 800-207** (Zero Trust Architecture) y **CISA Zero Trust Maturity Model v2.0**. Todo el stack es Open Source (\$0).

1. Principios rectores (NIST SP 800-207)

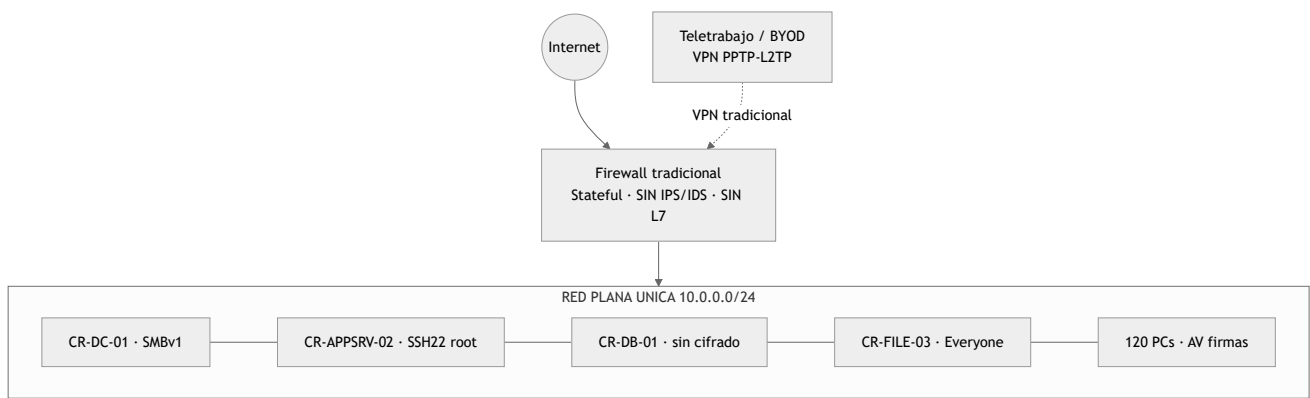
La junta directiva de CREATIC declaró obsoleto el modelo de "perímetro de castillo". El rediseño se basa en los tres axiomas de Zero Trust:

- 1. **Verificar continuamente** — ninguna conexión se confía por su origen de red; cada acceso se autentica (MFA) y se autoriza por política, y se **reevalúa** durante la sesión.
- 2. **Mínimo privilegio** — cada usuario/dispositivo accede solo al recurso y puerto que necesita. El tráfico entre segmentos pasa **siempre** por el NGFW.
- 3. **Asumir la brecha** — se segmenta para que un compromiso quede contenido (radio de explosión mínimo) y se monitorea todo (ver Módulo 3, Wazuh).

Bajo NIST 800-207, el NGFW actúa como **PEP** (Policy Enforcement Point) y Keycloak + el evaluador de postura conforman el **PDP** (Policy Decision Point).

2. Estado actual (Antes) — la red plana

Ver diagrama: [diagramas/topologia-antes.mmd](#).



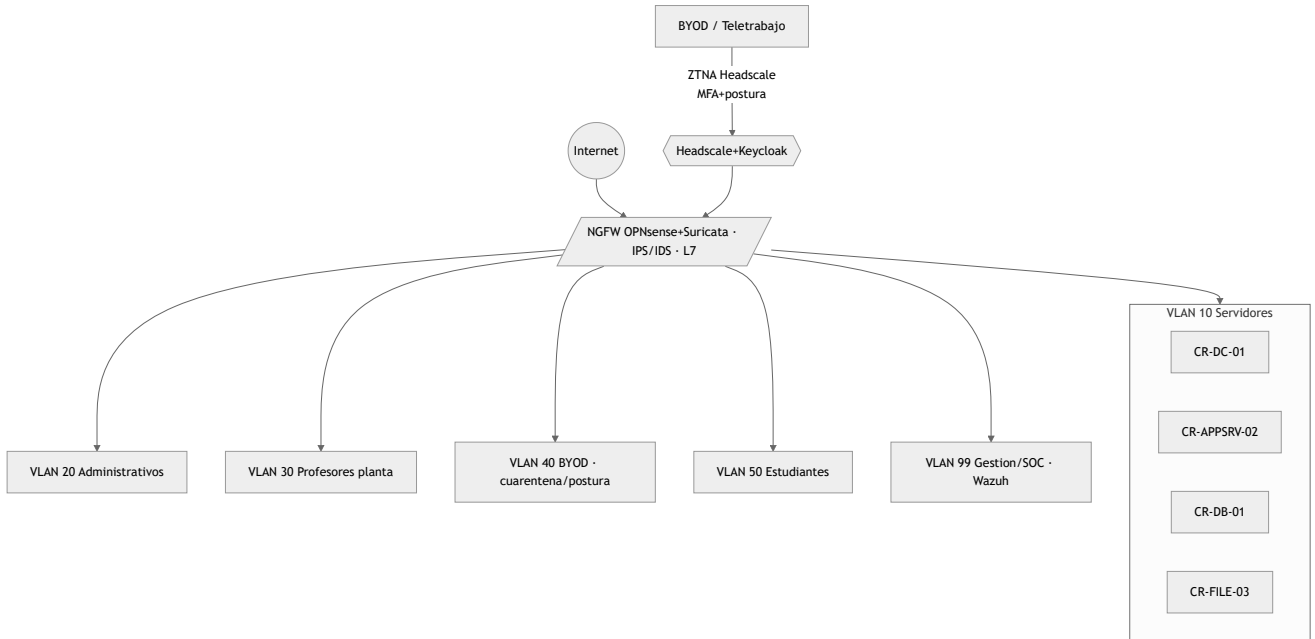
Problemas críticos del estado actual:

Problema	Riesgo que habilita
Un único dominio de difusión (sin VLANs)	Movimiento lateral libre tras un compromiso
Servidor web (CR-APPSRV-02) en el mismo segmento que la BD de finanzas (CR-DB-01)	Un RCE en el portal alcanza directamente las calificaciones y finanzas

Firewall sin IPS/IDS ni inspección L7	Exploits y C2 atraviesan sin detección
VPN PPTP/L2TP solo con usuario/contraseña	Credenciales robadas = acceso total a la LAN; sin verificación de postura
BYOD docentes sin visibilidad	Dispositivos comprometidos entran a recursos internos

3. Estado propuesto (Después) — microsegmentación Zero Trust

Ver diagrama: [diagramas/topologia-despues.mmd](#) .



3.1 Esquema de microsegmentación (VLANs)

VLAN	Segmento	Población	Subred (ej.)	Política de acceso (mínimo privilegio)
10	Servidores críticos	CR-DC-01, CR-APPSRV-02, CR-DB-01, CR-FILE-03	10.10.10.0/24	Solo flujos explícitos; CR-DB-01 acepta 3306 solo desde CR-APPSRV-02
20	Administrativos/directivos	120 equipos	10.10.20.0/24	Acceso a apps internas vía NGFW; sin SSH/RDP directo a VLAN 10
30	Profesores de planta	100 equipos gestionados	10.10.30.0/24	Acceso a portal académico; sin acceso a finanzas
40	BYOD docentes contratistas	250 dispositivos no gestionados	10.10.40.0/24	Cuarentena por defecto ; acceso solo tras chequeo de postura; navegación a SaaS
50	Estudiantes	5,500	10.10.50.0/22	Solo Internet/SaaS; bloqueo total hacia VLAN 10
99	Gestión / SOC (out-of-band)	Wazuh, administración	10.10.99.0/24	Aislada; solo administradores autenticados; recibe logs de todos los segmentos

3.2 Matriz de flujos permitidos (lista blanca — todo lo demás se deniega)

Origen → Destino	Puerto/Servicio	Justificación
VLAN 20/30 → CR-APPSRV-02 (VLAN 10)	443/HTTPS	Uso del portal académico
CR-APPSRV-02 → CR-DB-01 (VLAN 10)	3306/MySQL	Única ruta legítima a la BD de finanzas
Administración (VLAN 99) → VLAN 10	2222/SSH, 3389/RDP	Gestión autenticada con MFA
Todas las VLAN → VLAN 99	1514/1515 (Wazuh agent)	Envío de logs al SIEM
VLAN 50 (estudiantes) → VLAN 10	DENEGADO	Estudiantes nunca tocan servidores
VLAN 40 (BYOD) → cualquiera	DENEGADO hasta validar postura	Asumir la brecha en dispositivos no gestionados

Contención del RCE (enlaza con M4): aunque un atacante logre RCE en CR-APPSRV-02, la microsegmentación impone que la única conexión saliente permitida a la BD sea 3306 desde el propio servicio web. No puede pivotar a CR-DC-01 ni exfiltrar por puertos arbitrarios; el NGFW+Suricata detecta el escaneo/C2 y Wazuh dispara la alerta de movimiento lateral.

4. NGFW con IPS/IDS — OPNsense + Suricata

Elección Open Source: OPNsense (firewall/router de nueva generación) con **Suricata** como motor de IPS/IDS en línea. (Alternativa evaluada: pfSense + Snort.)

Capacidad	Cómo se cubre
Inspección de Capa 7	Reglas de aplicación de OPNsense + Suricata (app-layer)
IPS/IDS con firmas	Suricata con reglas ET Open (Emerging Threats, gratuitas)
Punto de control inter-VLAN	Router-on-a-stick / interfaces por VLAN; todo el tráfico este-oeste lo arbitra el NGFW
Filtrado de salida (egress)	Bloqueo de C2 y exfiltración por puertos no autorizados

Viabilidad económica: OPNsense y las reglas ET Open son gratuitas; corre sobre hardware existente o una VM. Costo de licencia = **\$0**, cumpliendo la restricción de negocio.

5. ZTNA — reemplazo de la VPN tradicional (Headscale)

La VPN PPTP/L2TP se elimina por insegura (cifrado débil, sin postura, confianza implícita). Se sustituye por **ZTNA con Headscale** (implementación Open Source self-hosted del plano de control de Tailscale, basado en WireGuard).

Característica ZTNA	Beneficio frente a la VPN tradicional
WireGuard (cifrado moderno)	Reemplaza PPTP/L2TP, criptográficamente obsoletos
Identidad como perímetro	El acceso depende de quién y con qué dispositivo , no de la IP de red
Integración con IdP (Keycloak)	Exige MFA antes de emitir acceso

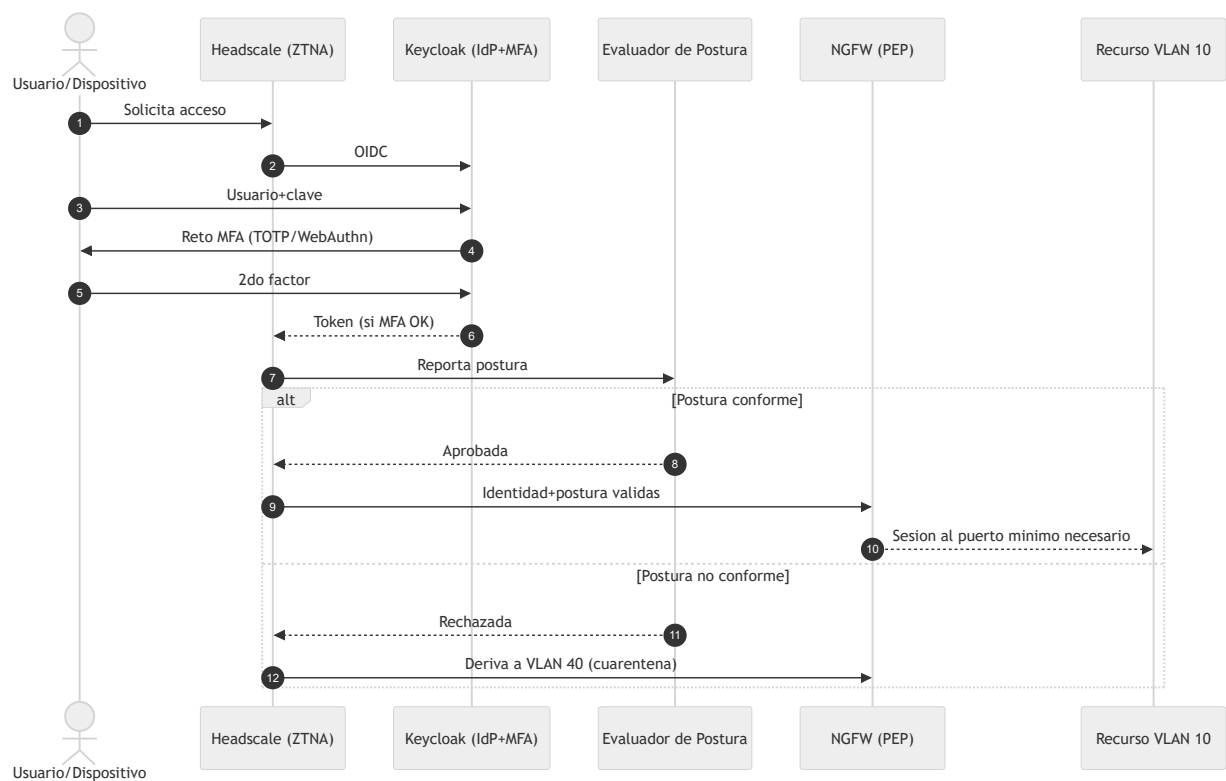
ACLs por usuario/grupo	Mínimo privilegio: un docente contratista nunca ve finanzas
Acceso a aplicación, no a red	No otorga una IP en la LAN; conecta a recursos puntuales

Alternativa evaluada: Cloudflare WARP / Zero Trust (free tier) — descartada como dependencia principal por preferir control total self-hosted y evitar dependencia de un SaaS externo.

6. MFA y flujo de autenticación (Keycloak)

IdP Open Source: Keycloak (OIDC/SAML), con segundo factor **TOTP** (Google Authenticator/FreeOTP) o **WebAuthn/passkeys** (resistente a phishing).

Ver diagrama: [diagramas/flujo-auth-mfa.mmd](#).



Este flujo materializa la **defensa contra el spear-phishing y el credential stuffing** (Módulo 1): aunque roben la contraseña, sin el segundo factor y sin un dispositivo con postura válida, el acceso se deniega.

7. Criterio de evaluación de postura del dispositivo

Antes de conceder acceso, el endpoint debe demostrar un estado mínimo de salud. Señales evaluadas:

Señal de postura	Criterio de aprobación	Si falla
Sistema operativo	Parches al día (no más de N días de retraso)	Cuarentena VLAN 40 + remediación
Cifrado de disco	BitLocker / LUKS activo	Denegar acceso a VLAN 10
EDR/antivirus	Agente Wazuh + AV activo y actualizado	Acceso limitado (solo SaaS)
Integridad	Sin jailbreak/root; arranque seguro	Denegar

Certificado de dispositivo	Dispositivo enrolado y reconocido	Tratar como BYOD no confiable → VLAN 40
----------------------------	-----------------------------------	---

Estrategia para BYOD (250 docentes contratistas): por defecto entran a **VLAN 40 en cuarentena**. Solo tras superar el chequeo de postura obtienen acceso *condicional* y *mínimo* a recursos específicos. Los que no cumplen quedan limitados a navegación SaaS, nunca a la VLAN 10.

8. Mapeo a los 5 pilares de CISA Zero Trust Maturity Model v2.0

Pilar CISA ZTMM	Estado actual (Tradicional)	Estado propuesto (CREATIC)	Nivel objetivo
Identidad	Usuario/contraseña, sin MFA	Keycloak + MFA (TOTP/WebAuthn), SSO	Avanzado
Dispositivos	Sin visibilidad (BYOD ciego)	Postura obligatoria + agente Wazuh + cuarentena BYOD	Avanzado
Redes	Plana, sin IPS	Microsegmentación VLAN + NGFW OPNsense/Suricata IPS/IDS	Avanzado
Aplicaciones/Cargas	Despliegue manual FTP, sin auditoría	Acceso ZTNA por app + pipeline seguro (M4)	Intermedio→Avanzado
Datos	BD sin cifrado, permisos laxos	Cifrado at-rest (M5) + mínimo privilegio + clasificación	Intermedio→Avanzado

Los pilares transversales de CISA (**Visibilidad y Analítica** y **Automatización y Orquestación**) se cubren con Wazuh (M3) y la automatización de hardening (M5).

9. Viabilidad económica (la rúbrica la evalúa explícitamente)

Componente	Producto comercial típico	Alternativa adoptada	Costo licencia
NGFW + IPS	Palo Alto / Fortinet	OPNsense + Suricata + ET Open	\$0
ZTNA	Zscaler / Cloudflare Ent.	Headscale (self-hosted)	\$0
MFA / IdP	Okta / Entra ID P2	Keycloak	\$0
SIEM/EDR	Splunk / CrowdStrike	Wazuh (M3)	\$0

Costo total de licencias = \$0. El gasto se traslada a hardware existente/VMs y a horas de ingeniería (las que cubre este proyecto), respetando la restricción de la junta directiva.

10. Resumen de controles del Módulo 2 (para la matriz de trazabilidad)

- Microsegmentación VLAN → CISA ZTMM (Redes) / NIST 800-207 → `diagramas/topologia-despues.mmd`
- NGFW IPS/IDS → CISA ZTMM (Redes) → OPNsense + Suricata
- ZTNA + MFA + postura → CISA ZTMM (Identidad/Dispositivos); Ley 81 Art. 13 → `diagramas/flujo-auth-mfa.mmd`
- Cifrado de datos y mínimo privilegio → CISA ZTMM (Datos) → se implementa en M5

Módulo 5 — Automatización de Hardening

Peso en la rúbrica: 20% (Calidad y lógica de los scripts). Marcos: **CIS Benchmarks** (Windows Server / Linux) y **NIST SP 800-123**. Código real en `ansible/` y `powershell/`. **No son recomendaciones en texto plano: es infraestructura como código, ejecutable, parametrizada y verificada.**

1. Los 3 criterios de aceptación (cómo se cumplen)

Criterio	Cómo se implementa
1. Parametrización	Linux: todas las variables en <code>ansible/group_vars/all.yml</code> . Windows: bloque <code>param()</code> al inicio del <code>.ps1</code> . Cero valores hardcoded en la lógica.
2. Comentarios en español	Cada bloque lógico lleva un comentario <code>#</code> qué / para qué explicando la intención y la justificación de seguridad.
3. Verificación post-hardening	Linux: <code>ansible/tasks/verify.yml</code> con <code>assert</code> que falla el playbook si el estado no se cumple. Windows: bloque final de validación que reporta <code>[OK]</code> / <code>[FALLO]</code> y devuelve <code>exit 1</code> si algo falla.

2. Hardening Linux — Playbook de Ansible (CR-APPSRV-02, CR-DB-01)

2.1 Estructura (patrón roles/tasks/handlers)

```
ansible/
├─ inventory.ini           # hosts agrupados (linux_servers / windows_servers)
├─ group_vars/all.yml      # TODAS las variables parametrizadas
├─ hardening-linux.yml     # playbook principal (orquesta los bloques)
├─ tasks/
│  ├─ firewall.yml        # ufw: deny por defecto + lista blanca
│  ├─ ssh.yml             # root off, puerto, clave pública
│  ├─ servicios.yml       # deshabilitar servicios innecesarios
│  ├─ remediacion.yml      # CR-DB-01: cifrado at-rest + aislamiento
│  └─ verify.yml          # asserts de verificación
└─ handlers/main.yml      # reinicios idempotentes (sshd, mysql)
```

2.2 Decisiones de diseño clave

- **Orden firewall → SSH:** se abre el puerto SSH nuevo (2222) en `ufw` **antes** de reiniciar `sshd`, evitando quedar bloqueados fuera del servidor (un error clásico de hardening remoto).
- **validate:** `'sshd -t -f %s'`: cada cambio en `sshd_config` se valida sintácticamente **antes** de guardar; si la config es inválida, Ansible no la aplica.
- **Idempotencia:** los `handlers` reinician servicios **solo** cuando el archivo cambió.

2.3 Acciones del playbook (mapeadas al inventario)

Acción	Vulnerabilidad remediada	Archivo
--------	--------------------------	---------

Deshabilitar login directo de root por SSH	"root + contraseña en puerto 22" (CR-APPSRV-02)	tasks/ssh.yml
Cambiar puerto SSH (22 → {{ ssh_puerto }})	Reducir superficie/ruido de escaneos	tasks/ssh.yml
Exigir clave pública (sin contraseñas)	Credential stuffing / fuerza bruta	tasks/ssh.yml
Deshabilitar servicios innecesarios	Superficie de ataque (NIST 800-123)	tasks/servicios.yml
Firewall local ufw (deny + lista blanca)	Falta de control de host	tasks/firewall.yml
Cifrado at-rest InnoDB en CR-DB-01	"Sin cifrado de datos en reposo"	tasks/remediacion.yml
Aislar MySQL (bind-address + 3306 solo desde web)	"Mismo segmento que el web"	tasks/remediacion.yml

2.4 Ejemplo de parametrización (extracto de group_vars/all.yml)

```
ssh_puerto: 2222
usuario_admin: "adminseg"
ssh_permitir_root: "no"
fw_reglas_permitidas:
  - { puerto: "{{ ssh_puerto }}", proto: "tcp", origen: "10.10.99.0/24", desc: "SSH de gestion
db_bind_address: "10.10.10.13"      # CR-DB-01 escucha solo en su IP de VLAN 10
db_ip_web_autorizada: "10.10.10.12" # unica IP que puede conectar a 3306
```

2.5 Verificación (extracto de tasks/verify.yml)

```
- name: "VERIFICAR · SSH endurecido (puerto, root y contraseñas)"
  ansible.builtin.assert:
    that:
      - "'Port ' ~ ssh_puerto in ssh_conf.stdout"
      - "'PermitRootLogin ' ~ ssh_permitir_root in ssh_conf.stdout"
  fail_msg: "FALLO: la configuración de SSH no cumple el estado deseado."
```

Ejecución: ansible-playbook -i inventory.ini hardening-linux.yml (tras el primer run, reconectar con -e "ansible_port=2222").

3. Hardening Windows — Script PowerShell (CR-DC-01, CR-FILE-03)

3.1 Acciones (mapeadas al inventario)

Acción	Vulnerabilidad remediada	Técnica
Deshabilitar SMBv1 por completo	"SMBv1 activo" (CR-DC-01) — riesgo de ransomware	Set-SmbServerConfiguration + Disable-WindowsOptionalFeature
Políticas de contraseñas complejas	Credenciales débiles	net accounts + secdit (PasswordComplexity=1)

Inhabilitar cuenta Guest	Acceso anónimo	<code>Disable-LocalUser</code>
Corregir permisos "Everyone"	"Carpetas legibles por Everyone" (CR-FILE-03)	<code>icacls</code> (remueve S-1-1-0, concede al grupo autorizado)

3.2 Parametrización (extracto de `param()`)

```
param(
    [string[]] $CarpetasCriticas = @('C:\DatosAdministracion'),
    [string] $GrupoAutorizado = 'CREATIC\Administracion_RW',
    [int] $LongitudMinimaPwd = 14,
    [int] $VigenciaMaximaPwd = 60,
    [string] $CuentaInvitado = 'Guest'
)
```

3.3 Detalle técnico importante: permisos por SID

La remoción de "Everyone" usa el **SID bien conocido S-1-1-0** en lugar del nombre, para que funcione **independientemente del idioma del SO** (en Windows en español sería "Todos"). Es una decisión de robustez real:

```
icacls $carpeta /remove:g "*S-1-1-0" /T /C # quita Everyone/Todos por SID
icacls $carpeta /grant "${GrupoAutorizado}:(OI)(CI)M" /T /C # mínimo privilegio
```

3.4 Verificación (bloque final)

El script confirma cada cambio con `Get-SmbServerConfiguration`, `net accounts`, `Get-LocalUser` e `icacls`, imprime `[OK]` / `[FALLO]` por control y termina en `exit 1` si algo no se aplicó.

Nota de codificación: el `.ps1` se guarda en **UTF-8 con BOM**; en PowerShell 5.1 un script con acentos sin BOM se interpreta como ANSI y corrompe el texto en consola. (Verificado: el parser de PowerShell valida el script sin errores de sintaxis.)

4. Resumen de controles del Módulo 5 (para la matriz de trazabilidad)

- Líneas base de SO → CIS Benchmarks / NIST 800-123 → `ansible/`, `powershell/`
- Cifrado at-rest + aislamiento → NIST 800-207 (Datos) / Ley 81 (Art. 31) → `ansible/tasks/remediacion.yml`
- Verificación post-cambio → criterio de aceptación → `ansible/tasks/verify.yml`, bloque PS final

Módulo 3 — Operaciones de Seguridad y Endpoints (SOC/SIEM)

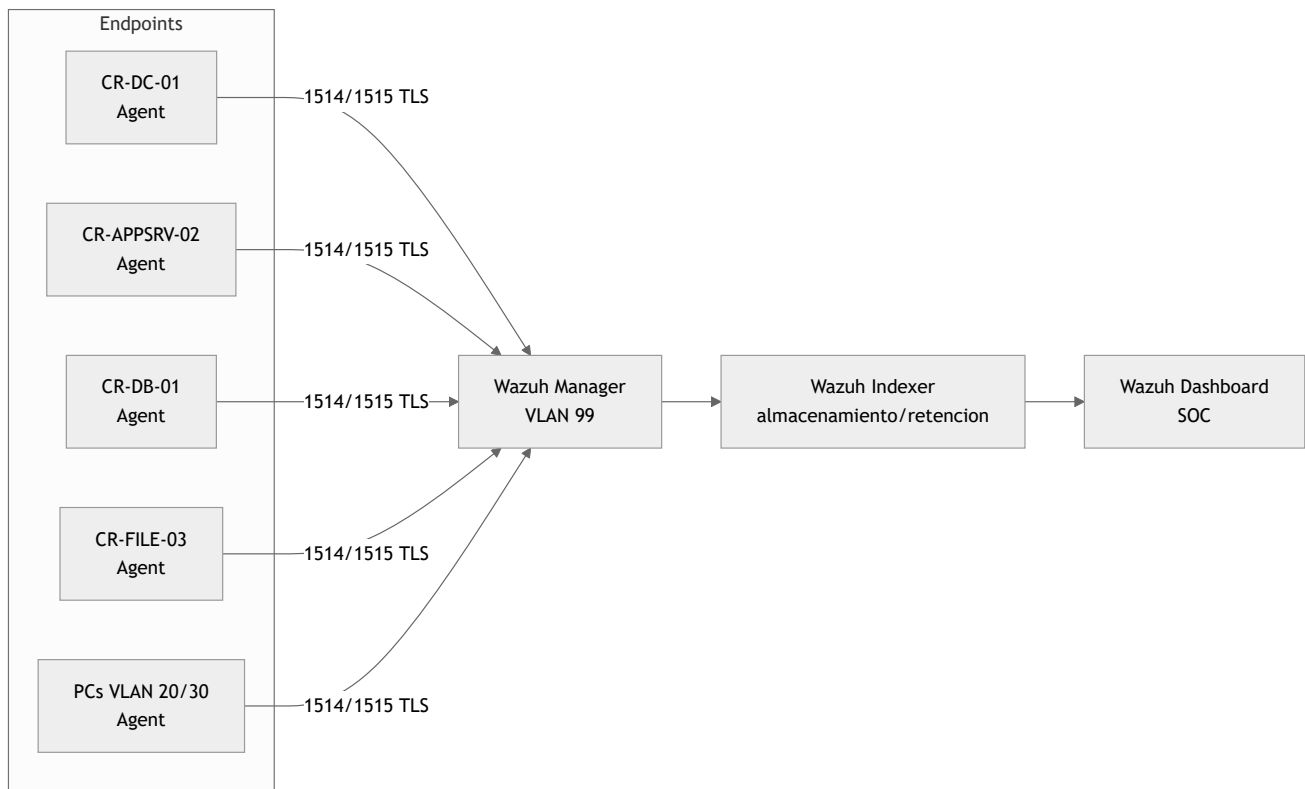
Restricción de negocio: presupuesto de licencias = \$0 (prohibido CrowdStrike, Splunk, etc.). Solución 100% Open Source de nivel empresarial: **Wazuh**. Marco de detección: **MITRE ATT&CK**. Enlaza con la retención de logs de la **Ley 81** (M6).

1. Plataforma elegida — Wazuh (EDR + SIEM Open Source)

Wazuh unifica EDR (agente en endpoint) y SIEM (correlación central) en un único stack gratuito. (Alternativa evaluada: Elastic Security — descartada por mayor complejidad operativa para el alcance de CREATIC.)

Arquitectura de componentes (nombrada explícitamente)

Componente Wazuh	Función	Ubicación
Wazuh Manager	Recibe eventos, aplica reglas de correlación, genera alertas	VLAN 99 (Gestión/SOC)
Wazuh Agent	Recolecta logs y telemetría en cada endpoint/servidor; FIM, detección de rootkits	CR-DC-01, CR-APPSRV-02, CR-DB-01, CR-FILE-03, equipos VLAN 20/30
Wazuh Indexer	Almacena e indexa los eventos (búsqueda y retención)	VLAN 99
Wazuh Dashboard	Visualización, paneles del SOC, gestión de alertas	VLAN 99 (acceso solo de administradores con MFA)



2. Fuentes de ingesta (mínimo exigido + ampliación)

Fuente	Activo	Cómo se ingiere
Syslog	CR-APPSRV-02, CR-DB-01 (Debian)	Agente Wazuh + lectura de <code>/var/log/auth.log</code> , <code>/var/log/syslog</code> , log de MySQL
Windows Event Log	CR-DC-01, CR-FILE-03	Agente Wazuh (canal Security, System, Application)
Logs de aplicación	Apache (Portal Académico)	<code>access.log</code> / <code>error.log</code> vía agente
Logs del NGFW	OPNsense/Suricata	Syslog remoto hacia el Manager (alertas IPS/IDS)
Logs de autenticación	Keycloak (MFA)	Syslog/HTTP hacia el Manager

Cobertura del inventario: los 4 servidores envían Syslog/Windows Event al Manager, cumpliendo el mínimo exigido. La inclusión del NGFW y Keycloak da visibilidad de red e identidad (pilares CISA ZTMM Redes e Identidad).

3. Reglas de correlación / alertas (≥3 — aquí 4)

Implementadas en `siem/reglas-correlacion.xml` . Cada regla tiene **criterio de disparo** explícito y mapeo a **MITRE ATT&CK**:

ID	Alerta	Criterio de disparo	MITRE	Nivel
----	--------	---------------------	-------	-------

100010	Fuerza bruta / credential stuffing SSH	≥6 fallos de login SSH desde la misma IP en 120 s	T1110, T1078	10
100020	Movimiento lateral a la BD de finanzas	Conexión a CR-DB-01:3306 desde un origen ≠ CR-APPSRV-02	T1021, T1210	12
100030	Uso/intento de SMBv1	Evento Windows/IDS que referencia SMB1/SMBv1 (debió estar deshabilitado)	T1210, T1570	11
100040	Creación de cuenta / elevación de privilegios	Windows Event 4720 (cuenta creada) o 4732 (añadido a grupo privilegiado)	T1136, T1098	10

Las reglas **enganchan con la arquitectura**: la regla 100020 detecta exactamente la violación de la *matriz de flujos permitidos* del Módulo 2. Esto es deliberado: una alerta del SIEM debe corresponder a un control de diseño, no a un umbral arbitrario. (Clave para la defensa oral.)

4. Estrategia de visibilidad para BYOD (250 docentes contratistas)

Los equipos BYOD no admiten un agente gestionado por la institución de forma forzosa. Estrategia en capas, coherente con Zero Trust (asumir la brecha):

1. **Sin agente = sin confianza**: por defecto, los BYOD entran a la **VLAN 40 en cuarentena** (ver M2). No se les concede acceso a la VLAN 10 sin superar el chequeo de postura.
2. **Visibilidad de red (sin agente)**: el **NGFW/Suricata** inspecciona su tráfico L7 y envía alertas IPS/IDS al Wazuh Manager. Así hay telemetría aunque el dispositivo no tenga agente.
3. **Agente opcional para acceso ampliado**: a quien instale el agente Wazuh (multiplataforma) se le concede acceso condicional mayor; el agente reporta postura (parches, EDR, cifrado).
4. **Identidad como control**: Keycloak + MFA registra cada autenticación BYOD; la regla 100010 también cubre intentos sospechosos desde estos dispositivos.

5. Retención de logs (enlaza con Ley 81 — Módulo 6)

El **Wazuh Indexer** retiene los eventos según la política definida en el Módulo 6 (conforme a la Ley 81 de Panamá). Resumen técnico:

- Retención en caliente (búsqueda inmediata) y archivado comprimido para el plazo legal completo.
- Integridad de los logs (los registros de auditoría no deben poder alterarse) → soporta el valor probatorio ante la ANTAL.
- La implementación concreta (índices, *Index State Management*, cifrado del almacenamiento y plazos) se detalla en [docs/M6-cumplimiento-ley81.md](#).

6. Resumen de controles del Módulo 3 (para la matriz de trazabilidad)

- Stack SIEM/EDR Open Source → Wazuh (Manager/Agent/Indexer/Dashboard) → [siem/](#)
- Reglas de correlación → MITRE ATT&CK → [siem/reglas-correlacion.xml](#)
- Visibilidad BYOD → CISA ZTMM (Dispositivos/Visibilidad) → NGFW + agente opcional
- Retención de logs → Ley 81 → [docs/M6-cumplimiento-ley81.md](#)

Módulo 4 — Ciclo de Desarrollo Seguro (SecDevOps)

Peso en la rúbrica: 15% (Estrategia SecDevOps y mitigación de vulnerabilidad). Marcos: **OWASP Top 10 / OWASP ASVS** y **CISA/NIST — Defending Against Software Supply Chain Attacks**. Pipeline implementado en `cicd/pipeline.yml`.

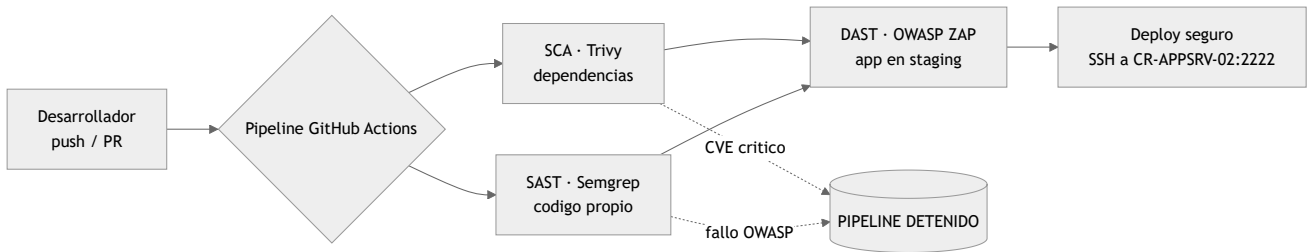
1. Problema de partida

CREATIC despliega el Portal Académico (CR-APPSRV-02) mediante **FTP/SCP manual**, con 3 desarrolladores, **sin pipelines** ni auditoría de código. Esto implica:

- No hay control de qué llega a producción ni quién lo subió (sin trazabilidad).
- Las vulnerabilidades (propias y de terceros) llegan a producción sin filtro.
- El canal FTP es inseguro (texto plano, sin integridad).

2. Solución — pipeline CI/CD con compuertas de seguridad (shift-left)

Se reemplaza el despliegue manual por un flujo automatizado en **GitHub Actions** con tres análisis encadenados. Si cualquiera detecta algo crítico, el pipeline **falla** y el artefacto **no llega** a CR-APPSRV-02.



Etap	Herramienta OSS	Qué analiza	Marco
SCA	Trivy (+ Dependabot)	Dependencias de terceros (CVEs conocidos)	CISA/NIST Supply Chain
SAST	Semgrep	Código fuente propio (inyección, XSS, secretos)	OWASP Top 10 / ASVS
DAST	OWASP ZAP	App desplegada en staging (caja negra)	OWASP ASVS
Deploy	SSH con clave (no FTP)	Publicación auditable a producción	—

3. Inyección de emergencia — la vulnerabilidad RCE en la librería de PDF

Escenario del profesor: una librería de terceros para generar PDF en el Portal Académico tiene una vulnerabilidad de **Ejecución Remota de Código (RCE)**.

3.1 Cómo el SCA lo previene (defensa en el pipeline)

1. **Detección automática:** el job `sca-dependencias` (Trivy) inspecciona los manifiestos de dependencias en **cada push/PR**. Al conocerse el CVE de la librería de PDF, Trivy lo marca como

CRITICAL .

2. **Bloqueo (gate):** Trivy corre con `exit-code: 1` y umbral `CRITICAL,HIGH` → el pipeline **falla** y el build con la librería vulnerable **nunca se despliega** a CR-APPSRV-02.
3. **Remediación dirigida:** el reporte indica la versión segura; **Dependabot** abre automáticamente un PR de actualización. Tras actualizar, el SCA pasa y el flujo continúa.
4. **Prevención continua:** como el SCA corre en cada cambio, una dependencia que se vuelva vulnerable *después* (nuevo CVE) se detecta en el siguiente pipeline.

Esto materializa la guía **CISA/NIST de cadena de suministro**: la seguridad de las dependencias se gestiona como parte del ciclo de vida, no como una revisión puntual.

3.2 Cómo la segmentación Zero Trust contiene el RCE (defensa en la arquitectura)

Supongamos que, pese al SCA, una versión vulnerable llega a producción y un atacante obtiene **RCE en CR-APPSRV-02**. La arquitectura del Módulo 2 **impide que alcance la BD de finanzas (CR-DB-01)**:

1. **Microsegmentación (VLAN 10 + matriz de flujos):** la única conexión saliente permitida desde CR-APPSRV-02 hacia CR-DB-01 es **3306/TCP**. El atacante no puede abrir SSH, RDP ni otros puertos hacia la BD ni hacia CR-DC-01.
2. **Regla de host (M5):** además de la VLAN, `ufw` en CR-DB-01 acepta 3306 **solo** desde `10.10.10.12` (CR-APPSRV-02). Cualquier intento de pivotar desde otra IP se deniega.
3. **Detección (M3):** si el atacante intenta escanear o conectar a la BD desde un origen anómalo, la **regla Wazuh 100020** dispara una alerta crítica de *movimiento lateral*.
4. **Datos cifrados (M5):** aunque tocara la BD por la ruta legítima, los datos están **cifrados en reposo** (InnoDB), reduciendo el valor de una exfiltración.
5. **Mínimo privilegio (NGFW egress):** el NGFW bloquea salidas a Internet por puertos arbitrarios, frenando el C2 y la exfiltración.

Resultado: el RCE queda **contenido** en el segmento del servidor web. La cadena *prevención (SCA) → contención (segmentación) → detección (SIEM) → mitigación de impacto (cifrado)* es exactamente la **Defensa en Profundidad** que exige el proyecto, y es una respuesta lista para la **defensa oral** ante el incidente sorpresa.

4. Resumen de controles del Módulo 4 (para la matriz de trazabilidad)

- Pipeline CI/CD seguro → OWASP / CISA Supply Chain → `cicd/pipeline.yml`
- SCA del RCE → CISA/NIST Supply Chain → Trivy + Dependabot
- SAST/DAST → OWASP Top 10 / ASVS → Semgrep + OWASP ZAP
- Contención del RCE → NIST 800-207 (microsegmentación) → M2 (matriz de flujos) + M5 (ufw, cifrado) + M3 (regla 100020)

Módulo 6 — Cumplimiento Regulatorio (Ley 81 de Protección de Datos, Panamá)

Peso en la rúbrica: 15% (junto con M1). Marco: **Ley 81 de 26 de marzo de 2019** sobre Protección de Datos Personales (Panamá), reglamentada por el **Decreto Ejecutivo 285 de 2021** y supervisada por la **ANTAI** (Autoridad Nacional de Transparencia y Acceso a la Información). En vigor pleno desde el **29 de marzo de 2021**.

⚠️ NOTA SOBRE EL ARTÍCULO 13 (leer). El enunciado del profesor pide justificar el MFA contra "el principio de seguridad técnica del **Artículo 13**". Sin embargo, en el **texto vigente** de la Ley 81: el **Art. 13** regula la **transferencia de datos sensibles** (no la seguridad); el **deber de medidas de seguridad** está en el **Art. 31**; el **principio de seguridad** se enumera en el **Art. 2**; y la **diligencia del responsable/custodio** en el **Art. 14**. Este documento **cita los artículos reales** y, donde el enunciado lo pide, referencia el Art. 13 con esta aclaración. *Se recomienda confirmar el número con el profesor por si usa otra edición/numeración.*

1. Por qué CREATIC está obligada

CREATIC trata **datos personales** (estudiantes, docentes) y **datos sensibles/financieros** (calificaciones, finanzas). La Ley 81 le impone principios de tratamiento (Art. 2), garantía de los **derechos del titular** (Art. 15, ARCO+), un **deber de seguridad** (Art. 31) y de **diligencia** (Art. 14). El incumplimiento habilita **sanciones de la ANTAI** (Arts. 42–43), entre **\$1,000 y \$10,000** y hasta clausura de registros.

2. Tabla de mapeo: Artículo Ley 81 → Control técnico → Entregable

Artículo / Norma	Exigencia	Control técnico propuesto	Entregable que lo implementa
Art. 2 — Principios (incl. <i>seguridad, confidencialidad, finalidad</i>)	Tratar los datos con seguridad, confidencialidad y para fines legítimos	MFA, mínimo privilegio, microsegmentación	docs/M2-arquitectura.md
Art. 31 — Medidas de seguridad	Adoptar medidas técnicas y organizativas apropiadas	MFA (Keycloak) + cifrado at-rest + hardening	diagramas/flujo-auth-mfa.mmd , ansible/tasks/remediacion.yml , powershell/Harden-Windows.ps1
Art. 14 — Diligencia del responsable/custodio	Cuidar los datos con la debida diligencia (responde por daños)	Hardening automatizado + SOC + control de accesos	ansible/ , powershell/ , siem/
Art. 15 — Derechos del titular (ARCO+)	Acceso, rectificación,	Procedimiento ARCO + integridad/disponibilidad	Política ARCO (anexo) + cifrado/respaldo

	cancelación, oposición y portabilidad	de datos para localizarlos	
Art. 21 — Irrenunciabilidad de derechos	Los derechos ARCO no se limitan por convenio	Diseño que garantiza el ejercicio efectivo de derechos	Política ARCO (anexo)
Art. 13 — Transferencia de datos sensibles (ref. del enunciado)	Controlar la transferencia de datos sensibles	Cifrado en tránsito (TLS/WireguArd) + reglas de flujo NGFW	docs/M2-arquitectura.md (matriz de flujos)
Decreto 285/2021 — Notificación de brechas (72 h)	Notificar el incidente (≈72 h) a la autoridad/titulares	IRP con flujo de notificación a la ANTAI	docs/M7-riesgos-irp.md
Retención y trazabilidad de logs	Poder auditar accesos y conservar evidencia	Retención de logs e integridad en Wazuh	siem/ , §4 de este documento
Arts. 42–43 — Régimen sancionatorio (ANTAI)	Evitar multas (\$1,000–\$10,000) y clausura	Conjunto completo de controles (defensa de diligencia)	Todo el repositorio

3. Justificación: cómo el MFA cumple el deber de seguridad (Art. 31; principio del Art. 2)

*Nota: el enunciado lo enmarca como "Artículo 13". Conforme al texto vigente, el deber técnico de seguridad corresponde al **Art. 31** y el principio de seguridad al **Art. 2**; la justificación aplica igual.*

El deber de seguridad exige medidas **proporcionales al riesgo** de los datos. Como CREATIC maneja datos sensibles y financieros, el riesgo es alto y exige autenticación fuerte:

1. **Mitiga el vector real del caso:** las credenciales administrativas de CREATIC ya estuvieron en la Dark Web. El **MFA** (Keycloak con TOTP/WebAuthn) impide que una contraseña robada baste para acceder — exige un segundo factor en posesión del titular legítimo.
2. **Resistencia a phishing:** con **WebAuthn/passkeys**, el segundo factor se liga al dominio, neutralizando el spear-phishing/vishing a docentes (vector inicial del caso y de M-Trends 2026).
3. **Proporcionalidad:** el MFA se exige especialmente para acceder a la VLAN 10 (datos sensibles) y a la gestión, alineando la intensidad del control con la sensibilidad del dato.
4. **Verificación continua (Zero Trust):** el acceso se reevalúa con la postura del dispositivo, sosteniendo el deber de seguridad en el tiempo, no como un control de una sola vez.

4. Política de retención de logs conforme a la Ley 81 (implementación en el SIEM)

Aspecto	Definición	Implementación técnica en Wazuh
---------	------------	---------------------------------

Qué se retiene	Logs de autenticación, acceso a datos, alertas y auditoría de los 4 servidores	Ingesta vía Wazuh Agent (Syslog + Windows Event)
Plazo de retención	Conforme a la Ley 81 / lineamientos ANTAI; se propone ≥ 12 meses en caliente + archivado para el plazo legal completo (<i>confirmar plazo en el Decreto 285/2021</i>)	<i>Index State Management</i> del Wazuh Indexer (hot → warm → cold/archive)
Integridad	Los registros no deben poder alterarse (valor probatorio ante la ANTAI)	Acceso estricto (VLAN 99) + <i>hashing</i> /firma de los índices de archivo
Confidencialidad	Los logs pueden contener datos personales	Cifrado del almacenamiento del Indexer + acceso solo con MFA
Disponibilidad para auditoría	La ANTAI o una investigación pueden requerirlos	Exportación desde el Wazuh Dashboard
Supresión al vencer	Borrado seguro tras el plazo (minimización)	Política automática de borrado del índice al expirar

El SIEM **sostiene el cumplimiento legal** (trazabilidad, integridad y plazos), no solo la detección.

5. Notificación de brechas (Decreto 285/2021) — enlace con el IRP

La notificación de incidentes (plazo ≈ **72 horas** según el reglamento) se ejecuta desde el **IRP (M7)**: el rol *Responsable Legal/Comunicaciones* notifica a la ANTAI y a los titulares afectados, con la naturaleza del incidente, los datos comprometidos y las acciones correctivas. Los **logs retenidos (Wazuh)** aportan la evidencia.

6. Resumen de controles del Módulo 6 (para la matriz de trazabilidad)

- Medidas de seguridad (Art. 31) / principio de seguridad (Art. 2) → MFA Keycloak + cifrado → M2, M5
- Diligencia (Art. 14) → hardening + SOC → M5, M3
- Derechos ARCO (Art. 15, 21) → política ARCO → anexo
- Notificación de brechas (Decreto 285) → IRP → M7
- Régimen sancionatorio (Arts. 42–43) → controles integrales → todo el repo

Sources / referencias web consultadas:

- ANTAI — Ley 81 entra en vigencia
- Texto oficial Ley 81 (Asamblea Nacional / Gaceta Oficial 28743-A)
- Decreto Ejecutivo 285 de 2021 (reglamento)

Módulo 7 — Gestión de Riesgos y Respuesta a Incidentes

Peso en la rúbrica: 25% (Sustentación Oral y Manejo de Incidentes bajo presión). Metodología de riesgos: **NIST SP 800-30 / ISO 27005**. Ciclo de respuesta: **NIST SP 800-61 Rev. 2**. Este módulo está diseñado para que cada acción de respuesta sea **rastreable** a un control de la arquitectura — requisito explícito de la defensa oral.

1. Metodología de la matriz de riesgos

Se aplica **NIST SP 800-30 / ISO 27005**. Cada riesgo se valora con:

- **Probabilidad (1–5):** 1 = muy improbable ... 5 = casi seguro.
- **Impacto CIA (1–5):** mayor valor de afectación sobre Confidencialidad, Integridad o Disponibilidad del activo.
- **Riesgo Inherente = Probabilidad × Impacto** (escala 1–25), *antes* de aplicar controles.
- **Riesgo Residual:** valor *después* de aplicar el control propuesto.

Bandas: **1–5 Bajo · 6–11 Medio · 12–19 Alto · 20–25 Crítico**.

2. Matriz de riesgos (10 riesgos; ≥ 1 por cada activo del inventario)

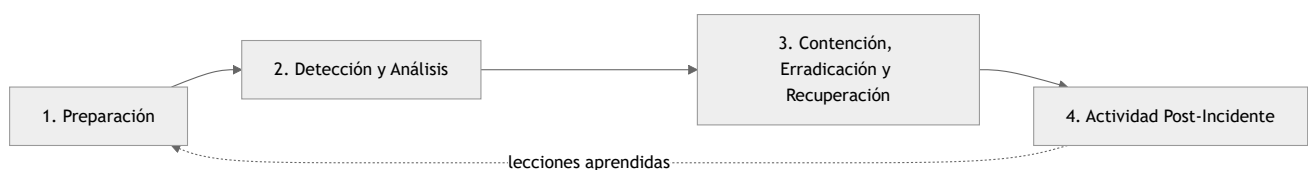
#	Activo	Amenaza	Vulnerabilidad	Prob (1-5)	Impacto CIA (1-5)	Riesgo Inherente	Control Propuesto (módulo)	Riesgo Residual
R1	CR-DC-01	Ransomware / movimiento lateral	SMBv1 activo, sin parches	4	5	20 Crítico	Deshabilitar SMBv1 (M5) + microsegmentación (M2) + EDR Wazuh (M3) + backups	8 Medio (P2×I4)
R2	CR-DC-01	Compromiso de credenciales de dominio	Sin MFA; credenciales en Dark Web	4	5	20 Crítico	MFA Keycloak (M2) + regla Wazuh 100040 (M3) + mínimo privilegio	8 Medio (P2×I4)
R3	CR-APPSRV-02	RCE vía librería de PDF vulnerable	Dependencia de terceros sin control SCA	4	4	16 Alto	Pipeline SCA/SAST/DAST (M4) + Dependabot	6 Medio (P2×I3)
R4	CR-APPSRV-02	Acceso no autorizado por SSH	SSH 22 con root y contraseña	4	4	16 Alto	Deshabilitar root + puerto 2222 + clave pública (M5) + regla 100010 (M3)	3 Bajo (P1×I3)
R5	CR-DB-01	Exfiltración de finanzas/notas (mov. lateral)	Mismo segmento que el web	4	5	20 Crítico	Microsegmentación + ufw 3306 solo desde web	6 Medio (P2×I3)

							(M2/M5) + regla 100020 (M3)	
R6	CR-DB-01	Robo de datos en reposo	Sin cifrado at-rest	3	5	15 Alto	Cifrado InnoDB/LUKS (M5)	4 Bajo (P2×I2)
R7	CR-FILE-03	Fuga de documentos administrativos	Permisos "Everyone/Todos"	4	4	16 Alto	Permisos mínimo privilegio vía icacls (M5) + segmentación (M2)	6 Medio (P2×I3)
R8	Red (toda)	Propagación / movimiento lateral	Red plana sin VLANs ni IPS	5	4	20 Crítico	VLANs + NGFW OPNsense/Suricata IPS/IDS (M2)	6 Medio (P2×I3)
R9	Endpoints BYOD	Dispositivo comprometido accede a recursos	BYOD sin control ni visibilidad	4	4	16 Alto	ZTNA + postura + cuarentena VLAN 40 (M2) + visibilidad NGFW (M3)	6 Medio (P2×I3)
R10	Usuarios (docentes)	Spear-phishing → robo de credenciales	Sin MFA; falta de concienciación	5	4	20 Crítico	MFA resistente a phishing/WebAuthn (M2) + EDR (M3) + concienciación	9 Medio (P3×I3)

Observación para la defensa: ningún riesgo crítico queda sin reducir. Las reducciones de *Probabilidad* provienen de controles preventivos (MFA, hardening, segmentación) y las de *Impacto* del cifrado y la contención por microsegmentación.

3. Plan de Respuesta a Incidentes (IRP) — NIST SP 800-61 Rev. 2

3.1 Ciclo de vida (4 fases)



Fase	Actividades en CREATIC	Apoyo de la arquitectura
1. Preparación	Roles CSIRT definidos, contactos ANTAI, runbooks, backups probados	Wazuh desplegado (M3), IRP documentado
2. Detección y Análisis	Triaje de alertas, confirmación, clasificación de severidad	Reglas de correlación Wazuh (M3), dashboards SOC
3. Contención, Erradicación, Recuperación	Aislar, eliminar la amenaza, restaurar desde backup limpio	Segmentación NGFW (M2), <i>active response</i> Wazuh, ZTNA/Keycloak
4. Post-Incidente	Informe, notificación ANTAI (Ley 81), lecciones aprendidas	Logs retenidos (M6) como evidencia

3.2 Roles del CSIRT interno

Rol	Responsabilidad principal
Líder de Incidente (IC)	Coordina la respuesta, decide la severidad y la activación del IRP
Analista SOC	Monitorea Wazuh, tria y valida alertas, ejecuta la contención técnica
Responsable de Infraestructura	Aplica aislamientos en NGFW/ZTNA, restaura sistemas y backups
Responsable Legal/Comunicaciones	Notifica a la ANTAI y a los titulares (Ley 81), gestiona la comunicación

3.3 Métricas de gestión (KPIs/KRIs)

Métrica	Definición	Objetivo CREATIC
MTTD (Tiempo Medio de Detección)	Desde que ocurre el evento hasta que el SOC lo detecta	Reducirlo con las reglas Wazuh (M3); objetivo < 1 h
MTTR (Tiempo Medio de Respuesta/Recuperación)	Desde la detección hasta la contención/recuperación	Objetivo < 4 h para incidentes críticos

4. Playbook de contención rápida — listo para la defensa oral

La defensa inyectará un incidente sorpresa; hay que dar **3 acciones exactas** que **provengan del propio IRP y arquitectura**. Esta tabla pre-mapea incidentes típicos a 3 acciones atómicas, cada una rastreable a un control concreto:

Incidente inyectado	Acción 1 (Contener)	Acción 2 (Cortar acceso)	Acción 3 (Detectar/Erradicar)
Ransomware en CR-FILE-03	Aislar la VLAN 10 en el NGFW OPNsense (bloquear este-oeste del host)	Revocar sesiones ZTNA y deshabilitar la cuenta afectada en Keycloak	Active response de Wazuh para matar proceso + bloquear IOC; restaurar desde backup
Movimiento lateral hacia CR-DB-01	Bloquear 3306 salvo CR-APPSRV-02 en ufw/NGFW (ya es la política base)	Aislar el host de origen en su VLAN y revocar su identidad	Investigar con la regla Wazuh 100020 y los logs retenidos (M6)
Credenciales admin comprometidas	Forzar cierre de sesión y reset en Keycloak + exigir MFA	Revocar tokens ZTNA del usuario; bloquear su acceso a VLAN 10	Revisar regla 100040/100010 en Wazuh; rotar secretos
RCE en el Portal Académico	Sacar CR-APPSRV-02 de balanceo / aislarlo en VLAN 10 vía NGFW	Cortar egress a Internet del host (frenar C2) en el NGFW	Disparar el pipeline SCA (M4) para identificar y parchear la dependencia

Mensaje para la junta (defensa): "Cada acción de contención no es improvisada: sale de un control que ya diseñamos — una VLAN, una regla de Wazuh, una política de Keycloak o del NGFW. Eso es Zero Trust operando bajo presión."

5. Resumen de controles del Módulo 7 (para la matriz de trazabilidad)

- Matriz de riesgos → NIST 800-30 / ISO 27005 → §2
- IRP y ciclo de vida → NIST 800-61 Rev. 2 → §3
- Acciones de contención rastreables → M2 (NGFW/VLAN), M3 (Wazuh), M5 (ufw/cifrado) → §4

- Notificación de brechas → Ley 81 / ANTAI → M6

Matriz de Trazabilidad — Marco → Control → Entregable

Artefacto transversal y vivo. Demuestra que **cada marco de referencia exigido por el profesor** (sección "Material de Referencia") se traduce en un control concreto y en un entregable verificable del repositorio. Es la herramienta principal para la defensa: ante cualquier pregunta, se localiza el marco, el control y el archivo que lo implementa.

1. Trazabilidad por marco de referencia

Marco de referencia	Pilar / Control que aporta	Entregable que lo implementa	Módulo
NIST SP 800-207 (Zero Trust Architecture)	Modelo conceptual ZT: verificación continua, mínimo privilegio, asumir la brecha	docs/M2-arquitectura.md , diagramas/topologia-despues.mmd	M2
CISA Zero Trust Maturity Model v2.0	5 pilares: Identidad, Dispositivos, Redes, Aplicaciones, Datos	docs/M2-arquitectura.md (tabla de madurez por pilar)	M2
CIS Benchmarks (Windows Server / Linux)	Líneas base de configuración segura por SO	ansible/hardening-linux.yml , powershell/Harden-Windows.ps1	M5
NIST SP 800-123 (General Server Security)	Defensa en profundidad a nivel de SO y servicios	ansible/tasks/*.yml , powershell/Harden-Windows.ps1	M5
OWASP Top 10 / OWASP ASVS	Verificación de seguridad de aplicaciones; diseño de SAST/DAST	cicd/pipeline.yml , docs/M4-secdevops.md	M4
CISA/NIST — Defending Against Software Supply Chain Attacks	Gestión de riesgo de dependencias de terceros; análisis SCA	cicd/pipeline.yml (Trivy/Dependabot), docs/M4-secdevops.md	M4
Mandiant M-Trends 2026	Inteligencia táctica de amenazas (citar nº de página)	docs/M1-amenazas.md	M1
MITRE ATT&CK	Mapeo de TTPs: phishing, credential stuffing, movimiento lateral	docs/M1-amenazas.md , siem/reglas-correlacion.xml	M1, M3
NIST SP 800-30 / ISO 27005	Metodología de matriz de riesgos	docs/M7-riesgos-irp.md	M7
NIST SP 800-61 Rev. 2 (Incident Handling)	Ciclo de vida del IRP; roles CSIRT; MTTR/MTTD	docs/M7-riesgos-irp.md	M7
Ley 81 de 2019 (Panamá)	Derechos ARCO, régimen sancionatorio ANTAI, deber de seguridad técnica	docs/M6-cumplimiento-ley81.md	M6

2. Trazabilidad de controles técnicos (control → marco → archivo)

Control técnico	Marco que lo respalda	Implementado en
-----------------	-----------------------	-----------------

Microsegmentación por VLANs (10/20/30/40/50/99)	CISA ZTMM pilar Redes; NIST 800-207	docs/M2-arquitectura.md , diagramas/topologia-despues.mmd
NGFW con IPS/IDS (OPNsense + Suricata)	CISA ZTMM pilar Redes	docs/M2-arquitectura.md
ZTNA con MFA y postura del dispositivo (Headscale + Keycloak)	CISA ZTMM pilares Identidad/Dispositivos; Ley 81 Art. 13	docs/M2-arquitectura.md , diagramas/flujo-auth-mfa.mmd
Deshabilitar root-SSH + cambiar puerto SSH	CIS Benchmark Linux; NIST 800-123	ansible/tasks/ssh.yml
Firewall local parametrizado (ufw/iptables)	CIS Benchmark Linux	ansible/tasks/firewall.yml
Cifrado at-rest CR-DB-01 + aislamiento de segmento	NIST 800-207 (Datos); Ley 81	ansible/tasks/remediacion.yml
Deshabilitar SMBv1	CIS Benchmark Windows	powershell/Harden-Windows.ps1
Políticas de contraseña + deshabilitar Guest	CIS Benchmark Windows	powershell/Harden-Windows.ps1
Corregir permisos "Everyone" en CR-FILE-03	CIS Benchmark Windows; mínimo privilegio	powershell/Harden-Windows.ps1
Ingesta de logs + reglas de correlación (Wazuh)	MITRE ATT&CK; Ley 81 (retención)	siem/reglas-correlacion.xml , docs/M3-soc-siem.md
Pipeline SAST/DAST/SCA	OWASP ASVS; CISA Supply Chain	cicd/pipeline.yml

Estado: matriz inicial creada en M0. Se actualiza al cerrar cada módulo, enlazando los archivos reales conforme se generan.